



Universidad Nacional de Costa Rica
Facultad de Ciencias Exactas y Naturales
Escuela de Informática

**Intercambio Tecnológico: Ciberseguridad
OWASP Top 10 y herramientas de monitoreo**

Curso:
Ingeniería de Sistemas III

Estudiantes:

Alexia Alvarado Alfaro (402580319)
Kendra Artavia Caballero (402580003)
Maria Araya Campos (402620649)
Gabriel Herrera Solís (402650111)
William Rodríguez Campos (118070563)
David Núñez Franco (119080008)

Profesores:

Mauricio Piedra Hidalgo
Sandra Lucía Cabrera Alzate

Fecha:
1 de marzo de 2026

Contents

1	Desarrollo del tema de investigación	2
1.1	Marco conceptual	2
1.2	OWASP Top 10:2025 y relación con el monitoreo	2
1.3	¿Para qué se utiliza el OWASP Top 10 en proyectos?	3
1.4	Herramientas de monitoreo y su papel	3
1.5	Ventajas y desventajas	4
1.6	¿Dónde conseguir más información?	4
2	Taller demostrativo (propuesta)	4
2.1	Objetivo	4
2.2	Idea de demostración	4
2.3	Plan de contingencia	5
3	Conclusiones	5
3.1	Conclusión profesional	5
3.2	Conclusión personal	5
3.3	Conclusión técnica	5
4	Recomendaciones	5

1 Desarrollo del tema de investigación

1.1 Marco conceptual

El OWASP Top 10 es un marco de referencia ampliamente utilizado para priorizar riesgos críticos en seguridad de aplicaciones web. Su propósito es aumentar la conciencia de riesgos y orientar acciones de mejora en equipos de desarrollo y seguridad.

El monitoreo de seguridad se entiende como el conjunto de prácticas, procesos e instrumentos para recolectar telemetría (logs, métricas, eventos), detectar comportamientos anómalos, generar alertas, y facilitar investigación y respuesta a incidentes. En términos prácticos, el monitoreo convierte eventos técnicos en evidencia accionable.

1.2 OWASP Top 10:2025 y relación con el monitoreo

A continuación se presenta una síntesis del OWASP Top 10:2025, enfocada en *qué* monitorear (señales) para tener evidencia y alertas útiles. La idea es conectar riesgos con telemetría:

Categoría	Riesgo resumido	Señales útiles de monitoreo
A01 Broken Access Control	Accesos no autorizados por fallas de control de acceso.	Logs de autenticación/autorización, intentos de acceso a recursos ajenos, cambios de rol, auditoría de acciones privilegiadas.
A02 Security Misconfiguration	Exposición por configuraciones inseguras (servidores, cloud, cabeceras, permisos).	Cambios de configuración, escaneo de hardening, alertas por endpoints administrativos expuestos, errores de configuración repetitivos.
A03 Software Supply Chain Failures	Compromisos/fallas al construir, distribuir o actualizar software (dependencias, CI/CD, repositorios).	Alertas por cambios en pipeline, nuevas dependencias, verificación de integridad de artefactos, eventos de repositorio (push/tag), vulnerabilidades en componentes.
A04 Cryptographic Failures	Uso incorrecto/insuficiente de criptografía y protección de datos.	Alertas por TLS débil/certificados próximos a expirar, fallos de cifrado, accesos a datos sensibles sin protección.
A05 Injection	Inyecciones en entradas (SQL/NoSQL/command, etc.).	Eventos WAF, patrones de payload malicioso, errores de BD, tasas anómalas de requests con caracteres sospechosos.

Categoría	Riesgo resumido	Señales útiles de monitoreo
A06 Insecure Design	Debilidades de diseño/arquitectura (controles faltantes).	Evidencia indirecta: patrones de abuso, ausencia de controles esperados (p. ej. falta de rate limiting), auditoría de flujos críticos.
A07 Authentication Failures	Fallos en autenticación e identidad (MFA ausente, sesiones débiles, etc.).	Intentos fallidos, credential stuffing, anomalías de login, cambios de contraseña, tokens inválidos, sesiones concurrentes sospechosas.
A08 Software or Data Integrity Failures	Suposiciones incorrectas sobre integridad de datos, actualizaciones y artefactos.	Verificación de firmas, eventos de integridad, cambios en artefactos desplegados, telemetría del pipeline y repositorios.
A09 Security Logging and Alerting Failures	Registro/monitoreo/alertas insuficientes; poca visibilidad y respuesta lenta.	Alarmas por ausencia de logs críticos, logs solo locales, integridad no protegida, umbrales sin definir, y alertas no atendidas a tiempo.
A10 Mishandling of Exceptional Conditions	Manejo incorrecto de errores/condiciones excepcionales que afecta seguridad y confiabilidad.	Errores repetidos en endpoints críticos, excepciones no controladas, mensajes de error anómalos, fallos que evitan registro consistente.

1.3 ¿Para qué se utiliza el OWASP Top 10 en proyectos?

En proyectos de software, el OWASP Top 10 se utiliza para:

- Priorizar historias técnicas de seguridad (backlog) según riesgos comunes.
- Guiar pruebas (revisión de código, pruebas dinámicas, validación de requisitos).
- Definir controles mínimos: control de acceso, autenticación, validación de entradas, monitoreo y alertas.
- Estandarizar comunicación entre desarrollo, QA y seguridad.

1.4 Herramientas de monitoreo y su papel

El monitoreo efectivo suele combinar:

- **WAF + reglas:** Por ejemplo, ModSecurity con OWASP Core Rule Set (CRS) para detectar y registrar patrones de ataque web.
- **SIEM/XDR:** Centralizar telemetría de endpoints, servidores, red y aplicaciones, correlacionar eventos y generar alertas.

- **Monitoreo de red:** IDS/NSM para observar tráfico (ej. Suricata / Zeek) y generar eventos.
- **Monitoreo de runtime y endpoints:** Para detectar comportamiento anómalo (ej. Falco en contenedores; osquery en endpoints).

1.5 Ventajas y desventajas

Ventajas: mejora priorización, reduce superficie de ataque, incrementa visibilidad y capacidad de respuesta, y aporta trazabilidad de eventos para auditoría.

Desventajas: mayor complejidad operativa, riesgo de fatiga por alertas (ruido), costos de almacenamiento/retención, y necesidad de buenas prácticas para no registrar información sensible (por ejemplo, no registrar contraseñas o tokens).

1.6 ¿Dónde conseguir más información?

La información más confiable se obtiene de:

- OWASP Top 10 (sitio oficial) y páginas de cada categoría.
- OWASP Cheat Sheet Series (por ejemplo, Logging Cheat Sheet).
- Documentación oficial de estándares (NIST) para monitoreo y gestión de logs.
- Documentación oficial de herramientas (Wazuh, Elastic, etc.).

2 Taller demostrativo (propuesta)

2.1 Objetivo

Demostrar, con un ejemplo funcional, cómo el monitoreo y alertamiento aportan visibilidad ante ataques típicos del OWASP Top 10.

2.2 Idea de demostración

- Utilizar una aplicación deliberadamente vulnerable (por ejemplo OWASP Juice Shop) en un entorno controlado.
- Generar tráfico malicioso de prueba (por ejemplo, un escaneo DAST o requests con payloads conocidos).
- Activar registro centralizado y alertas mínimas:
 - Alertar por múltiples intentos fallidos de autenticación.
 - Alertar por patrones de inyección detectados por WAF o logs.
 - Mostrar evidencia en un dashboard (línea de tiempo / eventos correlacionados).

2.3 Plan de contingencia

- Capturas de pantalla del dashboard y de eventos relevantes.
- Video corto pregrabado (2–3 minutos) del flujo de detección/alerta.
- Documentación local (PDF) en caso de falta de internet.

3 Conclusiones

3.1 Conclusión profesional

El OWASP Top 10 funciona como una guía práctica para priorizar riesgos comunes en aplicaciones web. Su integración con monitoreo y alertamiento fortalece la operación segura de sistemas, especialmente en ambientes productivos.

3.2 Conclusión personal

La investigación evidencia que no existe seguridad sostenible sin visibilidad: registrar, monitorear y alertar permite aprender del comportamiento real del sistema y responder ante incidentes de forma oportuna.

3.3 Conclusión técnica

El monitoreo requiere más que herramientas: exige eventos bien definidos, logs estructurados, integridad, retención adecuada y casos de uso de alerta. La correlación (SIEM/XDR) integra múltiples fuentes para dar contexto y reducir tiempos de respuesta.

4 Recomendaciones

- Adoptar el OWASP Top 10 como checklist de riesgos mínimos para el proyecto.
- Implementar logging estructurado con eventos auditables y contexto (usuario, IP, acción, resultado).
- Definir casos de uso de alertas (umbral, severidad, responsable, tiempo de atención).
- Proteger integridad de logs y evitar registrar datos sensibles (contraseñas, tokens).
- Probar periódicamente que escaneos y pruebas generan alertas; ajustar para reducir falsos positivos.

References

- [1] OWASP Top 10 Team. *OWASP Top 10:2025*. Disponible en: <https://owasp.org/Top10/2025/>. Consultado: 1 de marzo de 2026.

- [2] OWASP Top 10 Team. *A09:2025 Security Logging & Alerting Failures*. Disponible en: https://owasp.org/Top10/2025/A09_2025-Security_Logging_and_Alerting_Failures/. Consultado: 1 de marzo de 2026.
- [3] National Institute of Standards and Technology (NIST). *SP 800-137: Information Security Continuous Monitoring (ISCM)*. Disponible en: <https://csrc.nist.gov/pubs/sp/800/137/final>. Consultado: 1 de marzo de 2026.
- [4] National Institute of Standards and Technology (NIST). *SP 800-92: Guide to Computer Security Log Management*. Disponible en: <https://csrc.nist.gov/pubs/sp/800/92/final>. Consultado: 1 de marzo de 2026.
- [5] OWASP Cheat Sheet Series. *Logging Cheat Sheet*. Disponible en: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html. Consultado: 1 de marzo de 2026.
- [6] Wazuh Documentation. *Getting started with Wazuh*. Disponible en: <https://documentation.wazuh.com/current/getting-started/index.html>. Consultado: 1 de marzo de 2026.
- [7] OWASP. *OWASP Juice Shop*. Disponible en: <https://owasp.org/www-project-juice-shop/>. Consultado: 1 de marzo de 2026.